

SentinelVault

AI-Powered Adaptive Threat Intelligence Platform

A Complete Full-Lifecycle Framework — From File Interception to Community Threat Immunity

Scope Pre-Exploitation → Mid-Exploitation → Post-Exploitation	Core Idea Convincing digital-twin sandbox + covert AI observer agent	Outcome APT detection, zero-day discovery, community-wide immunity
--	---	---

Executive Summary

SentinelVault is an end-to-end, AI-driven malware defence and threat-intelligence platform built around a single core insight: sophisticated malware behaves differently when it believes it is inside a real organisation rather than a generic test environment. Instead of detonating suspicious files in a sterile sandbox — which advanced malware and APT tooling can detect and evade — SentinelVault detonates them inside a convincing **digital twin** of the organisation's own network, complete with fake domain controllers, employee sessions, file servers, and email systems. Malware that would normally stay dormant in front of a generic sandbox fully activates here, revealing its real objectives.

A covert, hypervisor-level AI agent watches this unfold without the file ever detecting its presence, tracking behaviour throughout the run, mapping it against the MITRE ATT&CK framework, and compiling a batch forensic brief the moment the run completes — a deliberate choice over live streaming, since verdicts based on a complete run are more reliable than ones issued against behaviour still in progress. Once the run finishes, all forensic evidence is cryptographically sealed, the sandbox is cryptoshredded beyond recovery, and a smarter, updated twin is rebuilt for the next file — ready to catch the next, more evasive variant. Every recommended containment, policy, or firewall action then passes through a human approval gate before anything is applied.

The output of every run doubles as threat intelligence: IOC packages, TTP-similarity scoring, reconstructed exploit chains, and a blast-radius/business-impact prediction. Regular IOCs share instantly with other organisations and public repositories such as MISP via STIX/TAXII; suspected zero-days instead follow a responsible-disclosure embargo, giving vendors time to patch before wider release — turning every detonation into protection for the community without tipping off other attackers first.

Document Structure

Phase	Focus	Diagrams Covered
1 — Pre-Exploitation	Interception, triage, and containment scope before any code runs	AI Entry Points · Main Detection Pipeline
2 — Mid-Exploitation	The digital twin, the covert AI agent, and adaptive containment	Digital Twin Architecture · Covert AI Agent · Adaptive Containment
3 — Post-Exploitation	Evidence handling, secure disposal, twin rebuild, and threat intelligence	Post-Exploitation Lifecycle · Threat Intelligence Platform

PHASE 1

Pre-Exploitation

What happens before a single line of the file's code is ever allowed to run

1.1 — Scoping the Attack Surface

Before building detection logic, the project honestly maps every way malware can enter an organisation, and states plainly which of those vectors SentinelVault v1 covers, partially covers, or leaves to other dedicated tools. The platform is deliberately scoped around the file-download attack surface — the most common entry point for ransomware, trojans, botnets, worms, and RATs — and is designed to sit alongside, not replace, an organisation's email gateway, endpoint agent, and firewall/IDS.

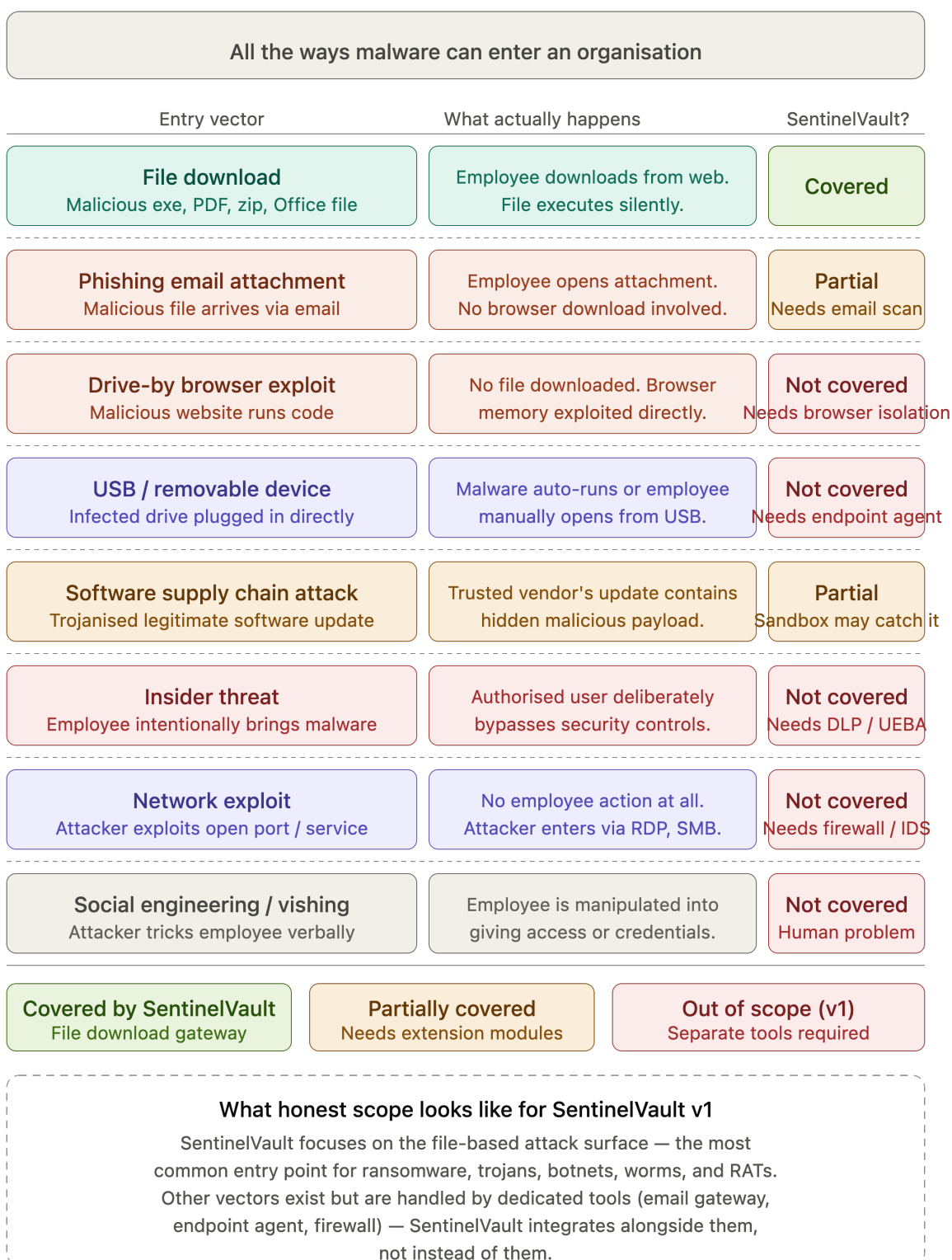


Figure 1.1 — All entry points malware can use, and SentinelVault's honest coverage scope for v1.

1.2 — The Interception and Triage Pipeline

Every file download is intercepted at the proxy/DNS layer and passed through an AI pre-screening engine that combines file-hash lookups, YARA rules, an ML classifier, and phishing-URL checks. Files are routed into one of three paths: immediate block-and-alert for known-bad files, pass-through for clearly benign files, or a deep, isolated cloud sandbox for anything uncertain. Inside that sandbox, static analysis, dynamic detonation, content-disarm-and-reconstruction (CDR), a honeypot network observer, behavioural scoring, and a ransomware "time machine" (continuous snapshotting with auto-rollback) all run in parallel.

The outputs feed an attacker-intent prediction engine and a 0–100 trust score, which a policy and decision engine converts into a final verdict: block with IT alert, or secure delivery of a CDR-cleaned file through a pre-signed, read-only viewer. Every verdict — blocked or delivered — updates an org-wide immune system, instantly sharing hashes, domains, and behavioural indicators to every other endpoint, and logs to the SIEM for the SOC dashboard.

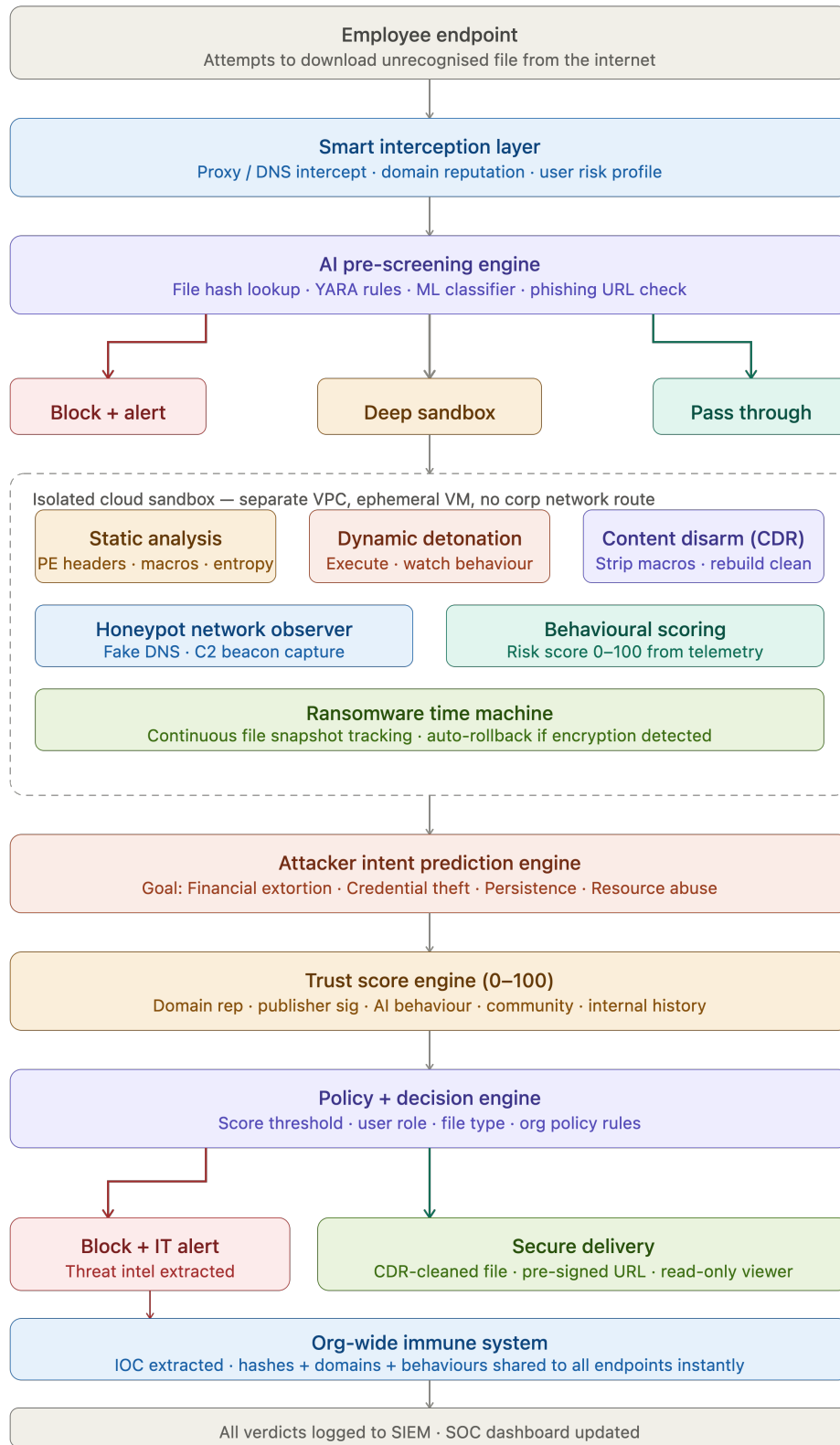


Figure 1.2 — The full pre-exploitation detection and containment pipeline, from endpoint download to secure delivery.

Mid-Exploitation

What happens while suspicious code is live and fully active inside the sandbox

2.1 — The Digital Twin: Defeating Sandbox-Aware Malware

A file arriving at this stage is still **unconfirmed** — the pre-screener has flagged it as suspicious, not malicious, because determining what it is and what type of threat it represents is precisely the sandbox's job. Generic sandboxes fail at that job against sophisticated malware because modern threats check their environment before acting — looking for a real logged-in user, real files, domain membership, and genuine network activity. If those checks fail, the malware goes dormant and shows no behaviour at all. SentinelVault's core innovation is to give it a convincing world to believe in: a full digital twin of the organisation's actual network, built from a one-time (and continuously updated) network-discovery and topology-modelling phase, so the replica uses the organisation's real hostnames, domain structure, and folder conventions rather than a generic template.

The twin's topology is kept deliberately complete rather than simplified: a fake domain controller with realistic Active Directory data, a file server with convincingly named documents, an **email server**, a **web proxy** providing a fake internet and DNS, employee laptops with live-looking sessions, a database, and a backup server. This matters because the digital twin's value depends entirely on offering the file multiple believable paths — collapsing the twin to two or three nodes leaves nothing for the lateral-movement mapper to actually map. A dedicated detonation point is where the file executes. Because every layer of its environment checks passes, it fully activates, and an observation layer (network tap, process tracer, file monitor, and C2 honeypot) captures everything: which node it targets first, its real C2 infrastructure, and its lateral-movement path, mapped directly onto blast-radius and business-impact predictions for the real network. Only once this full run is classified does the system refer to the file as malware of a specific type.

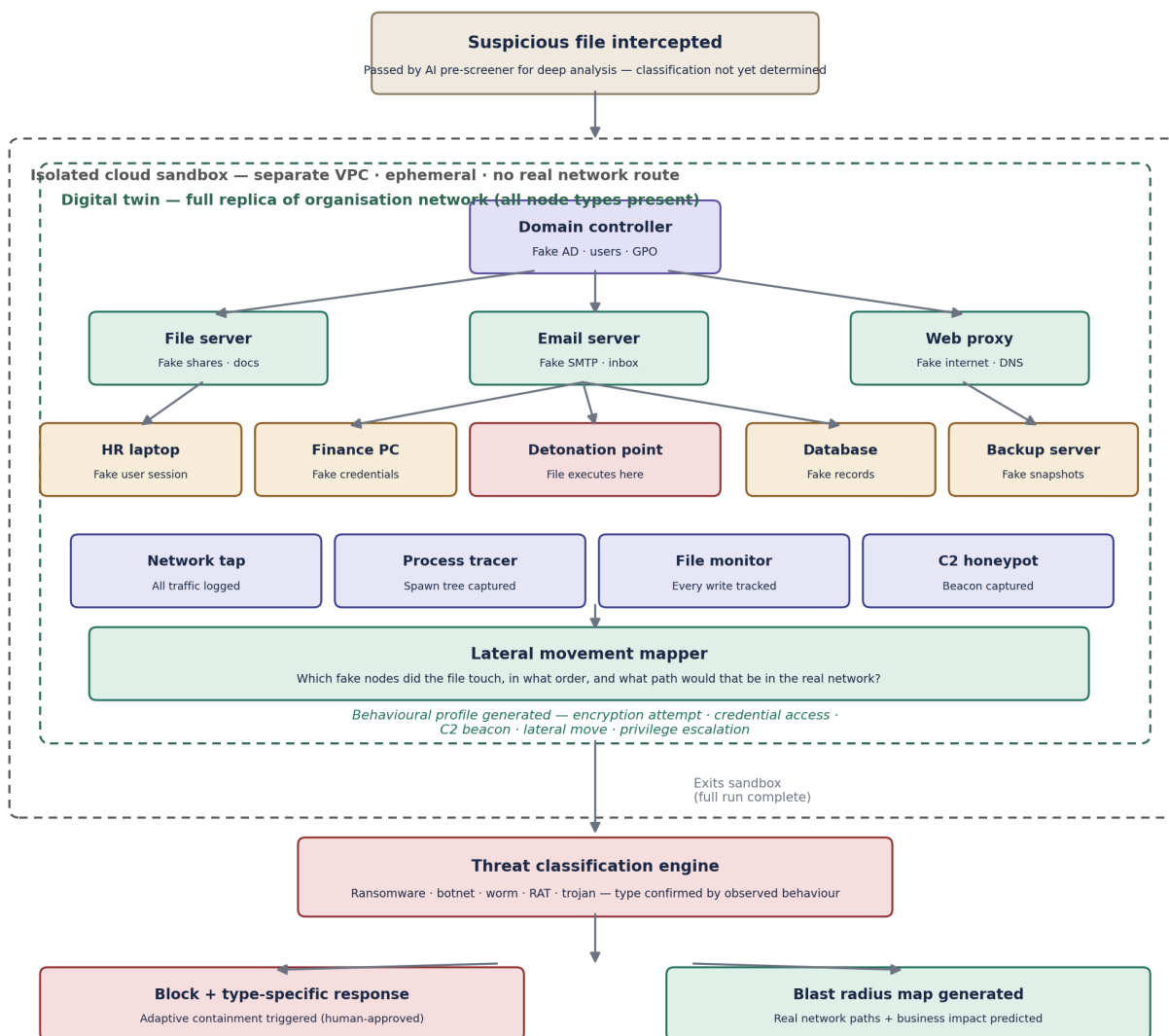


Figure 2.1 — The digital twin architecture with the full network topology intact, correctly labelled "suspicious file" at intake since classification has not yet occurred.

2.2 — The Covert AI Agent: A Hypervisor-Level Observer

A passive logger only records events. SentinelVault instead places an AI Security Analyst Agent inside the twin that interprets events as they happen — operating below the OS via VM introspection, reading CPU and memory state directly rather than touching anything the file's own process-visibility checks could detect. The malware sees a normal company network; the agent sees everything, invisibly.

The agent runs four functions continuously: a behaviour watcher tracking every process, call, and movement; an intent classifier inferring what the sample is trying to achieve; an ATT&CK; mapper tagging each technique against the MITRE framework; and a risk scorer tracking escalation level. This is a deliberate engineering choice: the agent compiles these into a full report only once the sandbox run has finished, rather than streaming interpretations mid-attack. Real-time streaming would force the AI to issue verdicts against **incomplete** behaviour — a genuinely harder and less reliable build for an MVP. Batch analysis, delivered as one packaged brief the moment the run completes, gives more accurate classifications and is far more buildable. The agent itself is stateless and ephemeral: it spins up with the twin and is destroyed with it, so it can never become the thing a sufficiently advanced sample compromises.

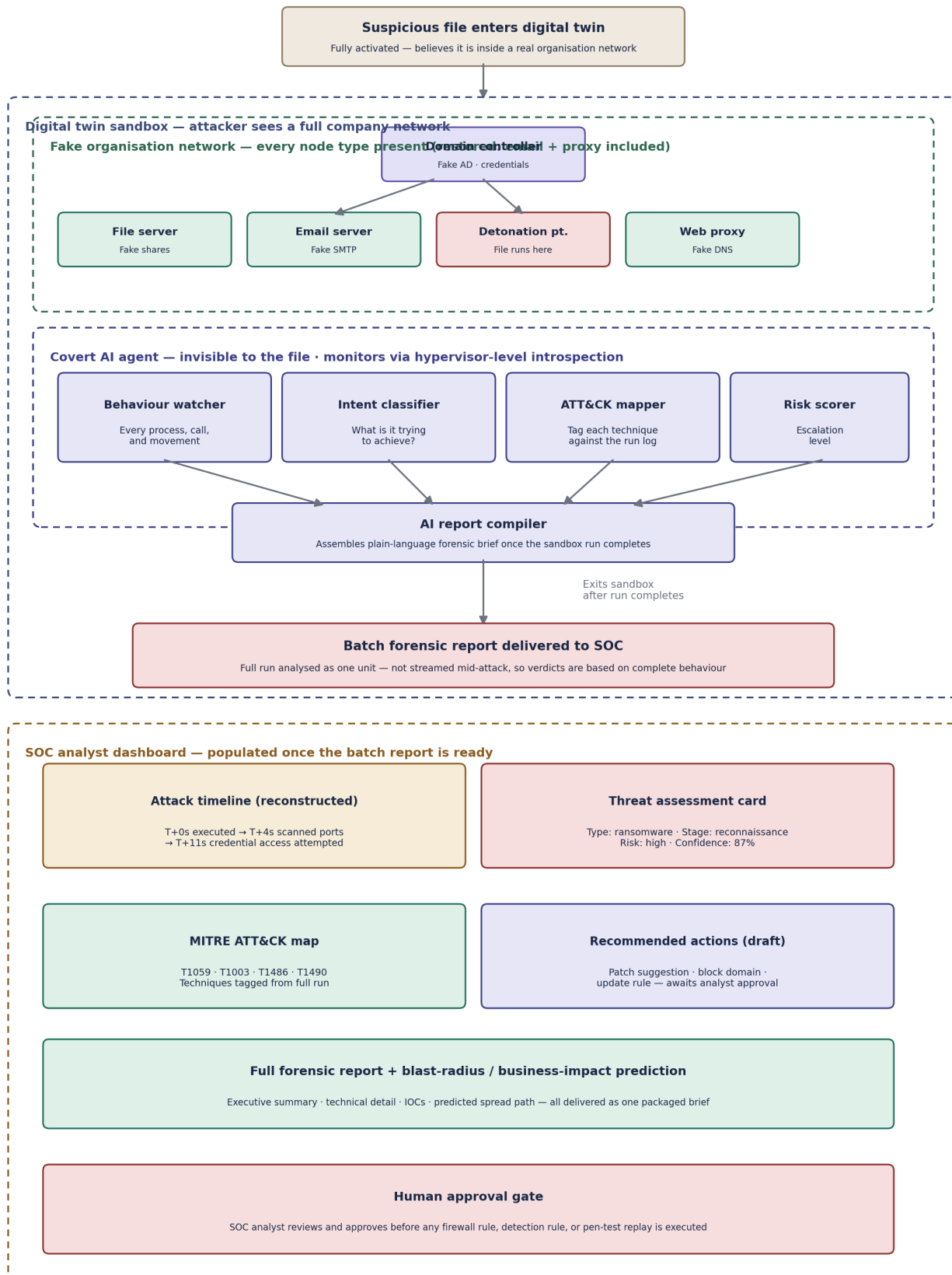


Figure 2.2 — The covert AI agent's observation stack, delivering a batch forensic report (not a live stream) to a SOC dashboard gated by human approval.

2.3 — Adaptive, Type-Specific Containment

Once the threat-classification engine identifies the malware family — ransomware, botnet, trojan, worm, or RAT — from behavioural profile matching, YARA, and ML model output, containment is not one-size-fits-all. Each family has its own detection signals (mass file changes and shadow-copy deletion for ransomware; periodic beaconing for botnets; SMB scanning and rapid propagation for worms; outbound C2 connections and keylogging for RATs) and its own tailored response playbook, from isolating the endpoint and rolling back files to sinkholing traffic and revoking credentials.

These responses converge into a blast-radius and infection-spread map predicting the real path the malware would take across the organisation's actual network, which is surfaced to the SOC as a suggested action panel — recommended, one-click-approved steps rather than a fully autonomous response — alongside a plain-language threat explanation for both the affected employee and the security team.

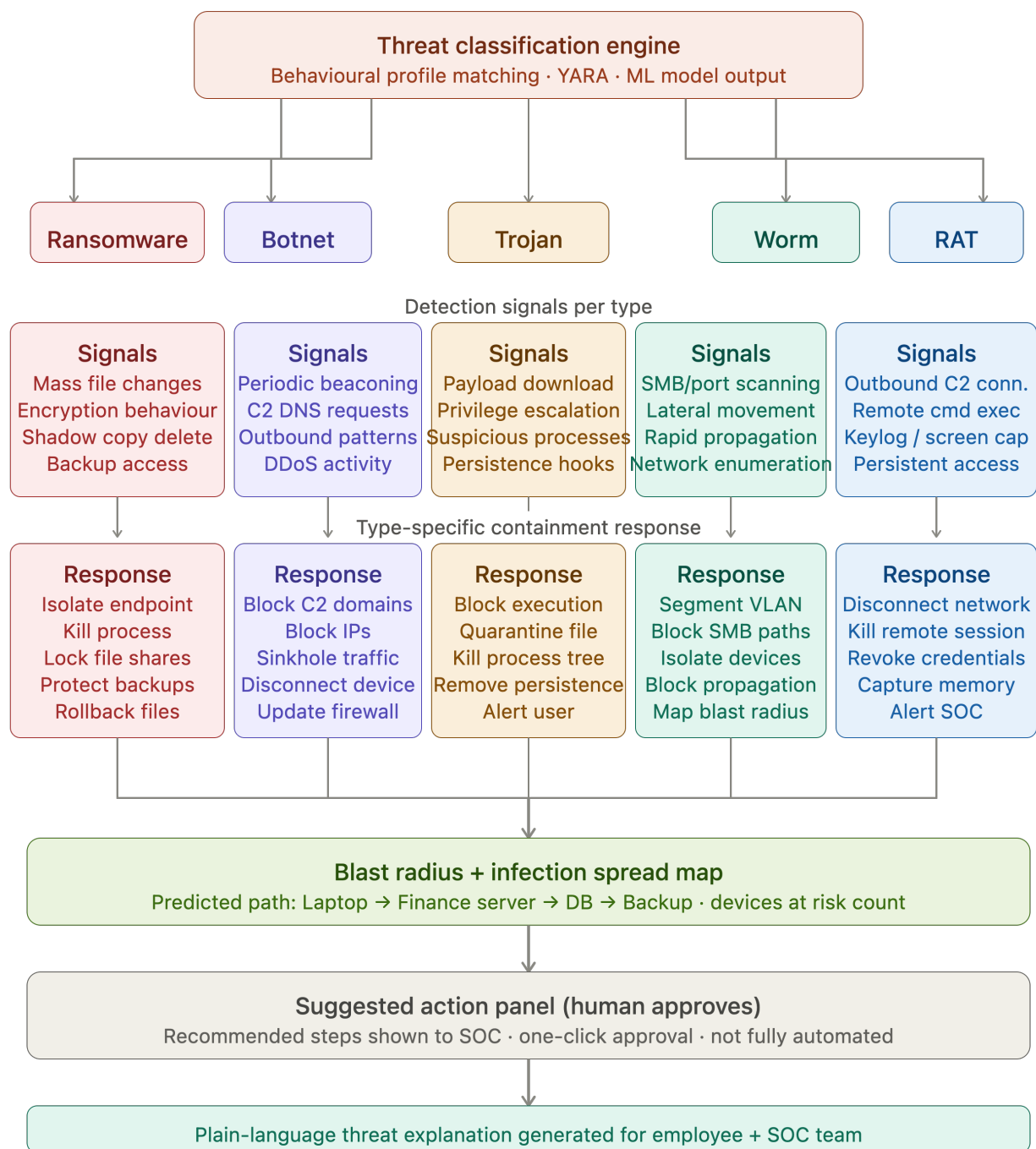


Figure 2.3 — Type-specific detection signals and containment responses, converging into a blast-radius prediction and human-approved action panel.

Post-Exploitation

What happens after the malware has finished acting — evidence, disposal, rebuild, and intelligence sharing

3.1 — Evidence Preservation, Secure Disposal, and Twin Rebuild

The moment a sandbox VM is terminated, volatile memory — containing decrypted malware code, injected shellcode, and C2 encryption keys — is gone forever. SentinelVault's AI agent therefore freezes and exports a full memory dump as its very first post-exploitation action, alongside a complete network capture, a file-system diff, and its own forensic report. All of this is hash-chained, cryptographically signed, and written to an immutable audit store outside the sandbox before disposal begins.

Disposal is then absolute: the VM is hard-terminated at the hypervisor level, memory is zeroed, the disk is cryptoshredded (destroying the encryption key so recovered storage blocks are permanently unreadable — the same technique banks use decommissioning hardware), and the VPC itself is torn down. A fresh twin is immediately rebuilt from the latest organisation network snapshot, with newly discovered vulnerabilities already patched, honeypots repositioned toward what the last attacker actually targeted, and the covert AI agent reinstalled — meaning each successive twin is measurably smarter than the one before it, while three things persist permanently across every cycle: the immutable audit store, the growing threat-intelligence database, and the continuously retrained AI classifier.

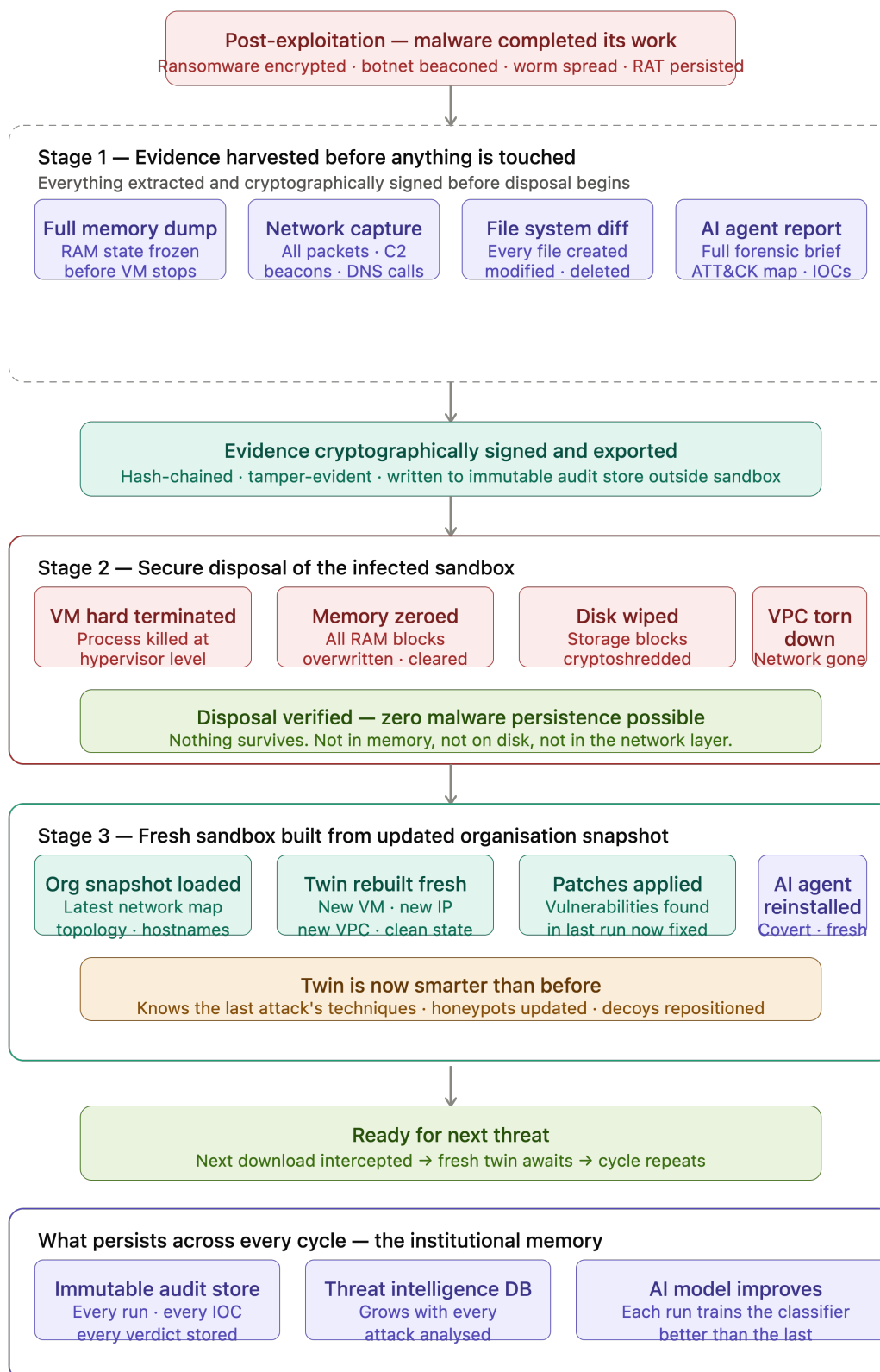


Figure 3.1 — The three-stage post-exploitation lifecycle: evidence harvest, secure disposal, and smarter twin rebuild.

3.2 — From Single Detonation to Community Threat Intelligence

The sealed evidence from every run feeds an intelligence-extraction engine that converts raw behavioural telemetry into structured outputs — deliberately scoped to what a single detonation can actually support. Rather than naming a specific threat actor, the engine produces a **TTP-similarity report**: a confidence score against known groups' known techniques, the same hedged approach firms like CrowdStrike and Mandiant use even with years of correlated data behind them. A zero-day candidate flag is raised where behaviour doesn't match any known technique, but this is treated as an **aspirational, reviewer-confirmed** capability rather than an automatic finding — proving something is genuinely novel requires diffing against a live, current CVE database, which is an ongoing research problem, not a flowchart box. Alongside these sit a full MITRE ATT&CK; technique map, a reconstructed exploit/technique breakdown, and a ready-to-distribute IOC package of hashes, IPs, and domains. This combination is what elevates SentinelVault from a defensive control into a genuine threat-intelligence platform, comparable in function to commercial products like Recorded Future, Mandiant Advantage, or CrowdStrike Falcon Intelligence.

Every run also produces a blast-radius and business-impact prediction — the projected spread path, devices at risk, and estimated downtime cost — reported as a parallel output alongside the containment verdict, not folded away as a side detail. This projection is the platform's clearest differentiator against commercial competitors and is preserved at every stage of the pipeline.

Internally, the batch intelligence brief drives concrete defensive actions — security-policy updates, firewall rule pushes, new SIEM/EDR detection rules, and a reconstructed-attack replay against the organisation's own systems — but **none of these execute automatically**. Every one sits behind a human approval gate: a single false positive auto-pushing a firewall rule, or auto-replaying an attack against production, is a liability the platform cannot absorb, so an analyst reviews and approves before anything is applied. Externally, community sharing is split by sensitivity rather than treated as one uniform pipeline. Regular malware IOCs broadcast instantly as STIX/TAXII bundles to platforms like MISP and connected organisations, since there's no benefit to withholding a known bad hash or domain. Zero-day candidates instead follow a **responsible-disclosure embargo** — typically on the order of ninety days — giving the affected vendor time to patch before public broadcast, so the platform never becomes the channel that tips off other attackers before a fix exists.

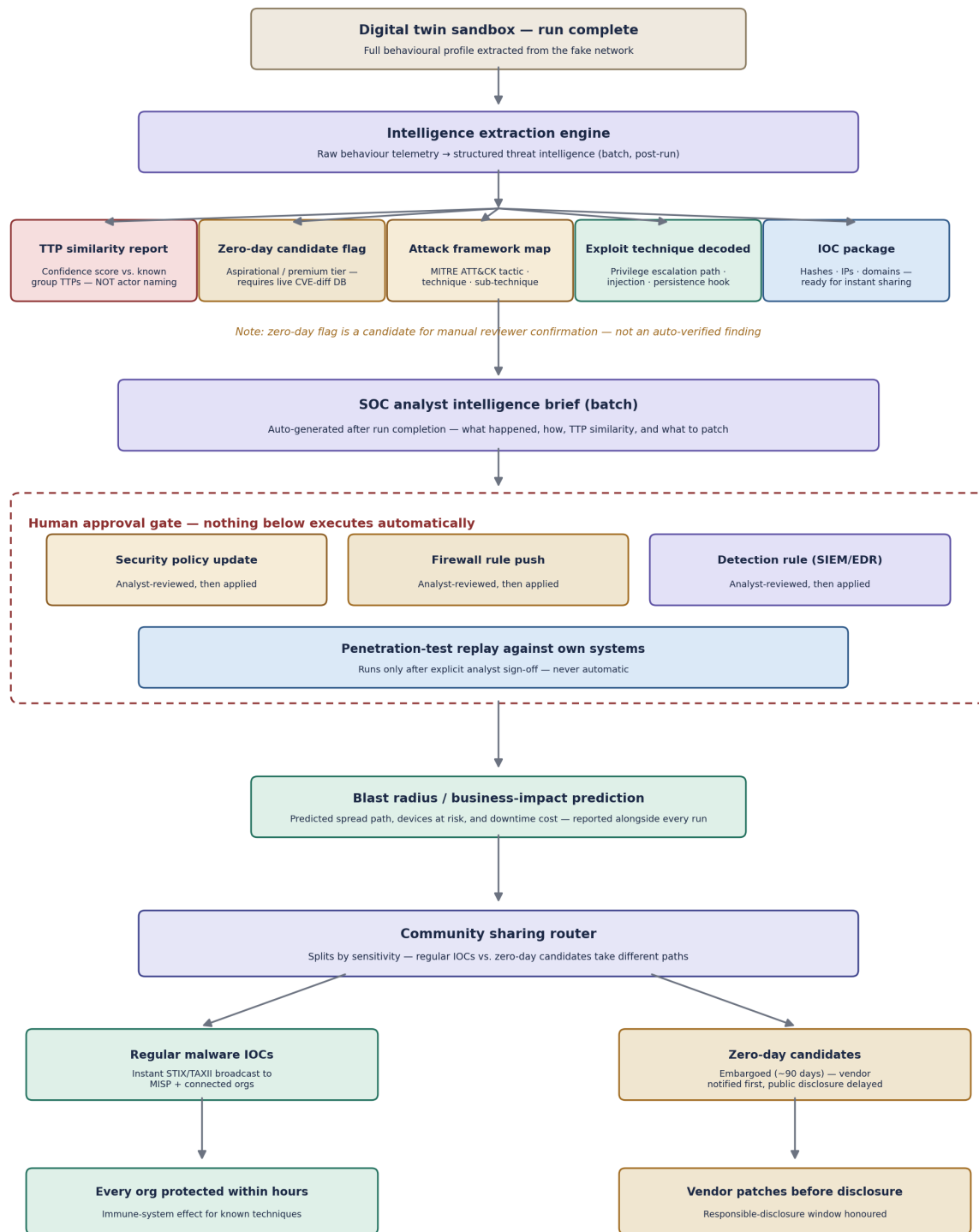


Figure 3.2 — The threat-intelligence platform: TTP similarity in place of actor attribution, a human approval gate before any internal action, and a sensitivity-based split between instant IOC sharing and embargoed zero-day disclosure.

Why the Full Lifecycle Matters

Most malware defence tools optimise a single stage — better detection at the gateway, or better forensics after the fact. SentinelVault's contribution is treating pre-exploitation, mid-exploitation, and post-exploitation as one continuous, self-improving loop:

Pre-exploitation — an AI-screened, risk-scored gateway that stops the majority of file-based threats before they ever run, while honestly deferring vectors outside its scope to dedicated tools.

Mid-exploitation — a digital twin convincing enough to defeat sandbox-aware evasion, watched by a covert AI agent that turns full-run behaviour into a batch, MITRE-mapped SOC brief — surfacing TTP-similarity signals and zero-day candidates for analyst review that generic sandboxes would miss entirely.

Post-exploitation — forensically sound evidence capture, provably complete disposal, and a twin that is measurably better after every run — plus community-wide threat sharing that converts one organisation's detonation into protection for every organisation on the platform.

Together, these three phases form a system that does not just block a file — it learns the attacker's playbook, defends the organisation against the next variant, and immunises the wider community against the one that comes after that.

SentinelVault — AI-Powered Adaptive Threat Intelligence Platform. Framework document compiled from project architecture diagrams: entry-point scoping, main detection pipeline, digital twin, covert AI agent, adaptive containment, post-exploitation lifecycle, and threat-intelligence platform.